DFIR Report: Active Directory Attack Chain Simulation and Investigation

Analyst: Zaineb Kchaou | **Environment:** Isolated virtual lab (host-only network) | **Report date:** 09/11/2026

1. Executive Summary

This report documents a simulated compromise of a small Active Directory environment and the subsequent investigation of that compromise using three independent evidence sources: SIEM logs (Splunk), live endpoint forensics (Velociraptor), and memory forensics (Volatility 3).

The simulated attacker gained an initial low-privilege domain credential (representing the outcome of a prior, out-of-scope initial-access step such as phishing), then escalated privileges through Kerberoasting, stole a Domain Administrator's credentials from a workstation's memory, and used those credentials to authenticate directly to the Domain Controller, achieving full domain compromise.

2. Scope and Methodology

2.1 Scope

- 1 Domain Controller (DC01, Windows Server, domain `corp.local`)
- 1 workstation (WIN10-01, Windows 10, domain-joined)
- 1 attacker machine (Kali Linux)
- 1 SIEM/forensics host (Ubuntu Server, running Splunk Enterprise and the Velociraptor server)

2.2 Methodology

The investigation followed a standard DFIR workflow: evidence collection (logs, live response, memory), correlation into a unified timeline, technique mapping against MITRE ATT&CK, and containment/recovery/hardening recommendations. Three independent sources were deliberately used so that findings in one source could be cross-validated against the others, rather than relying on a single point of evidence.

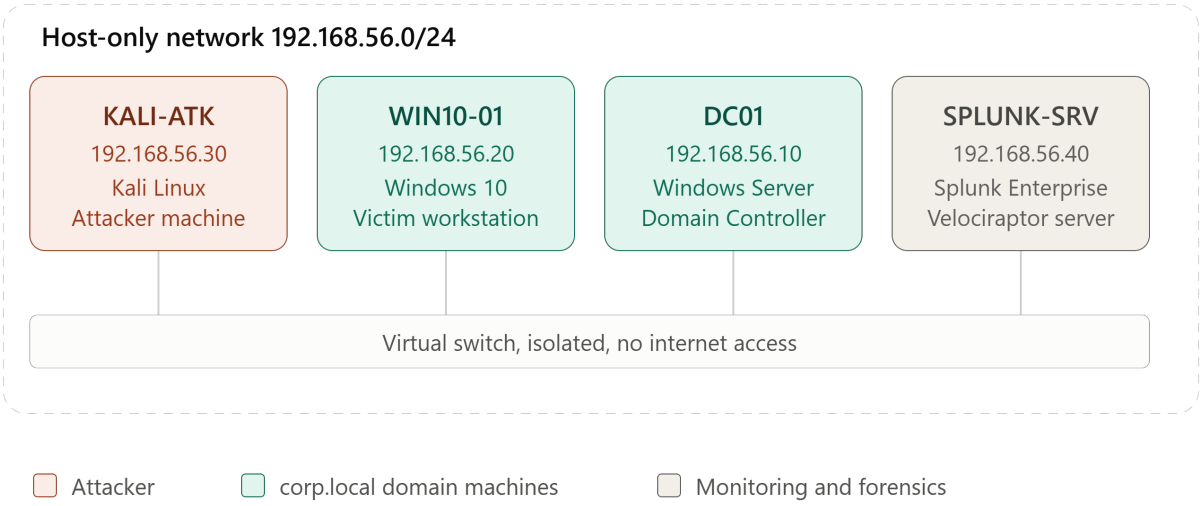
2.3 Tools and Evidence Sources

Tool	Role
Splunk Enterprise	Log aggregation and search (Windows Security log, Sysmon, PowerShell log)
Sysmon	Endpoint telemetry (process creation, process access, network connections)
Velociraptor	Live endpoint forensics (process state, Prefetch, persistence checks)
Volatility 3	Memory forensics (process list, network connections, command-line arguments)
BloodHound	Attack path reconnaissance / relationship mapping

3. Lab Architecture

```
[Host-Only Network: 192.168.56.0/24]
 |
 +-- DC01 (Windows Server) ............ 192.168.56.10
 |     Domain Controller for corp.local
 |
 +-- WIN10-01 (Windows 10) ............ 192.168.56.20
```

```
|     Victim workstation, domain-joined
|     Agents: Sysmon, Splunk Universal Forwarder, Velociraptor client
|
+-- KALI-ATK (Kali Linux) ............ 192.168.56.30
|     Attacker machine
|
+-- SPLUNK-SRV (Ubuntu Server) ....... 192.168.56.40
      Splunk Enterprise + Velociraptor server
```



Accounts involved:

Account	Role
`corp\svc-sql`	Service account with a registered SPN; Kerberoasting target; configured with a weak password to simulate a realistic misconfiguration
`corp\jdupont`	Low-privilege domain user; represents the attacker's initial foothold
`corp\it-admin`	Domain Administrator; had previously logged into WIN10-01, leaving credential material cached in memory

4. Attack Narrative

4.1 Reconnaissance

Using `jdupont`'s credentials, BloodHound was run against the domain to map account relationships and identify a path toward Domain Admin. The collection identified `svc-sql` as a Kerberoastable account sitting in a graph position with privileged groups (Administrators, Account Operators, Key Admins) holding write-level permissions over it, and confirmed `it-admin`'s membership in Domain Admins.

4.2 Kerberoasting

A TGS (service ticket) was requested for `svc-sql`'s registered SPN (`MSSQLSvc/sql01.corp.local:1433`) using `jdupont`'s credentials. The domain controller returned a ticket encrypted with `svc-sql`'s password hash (RC4 encryption). This ticket was cracked offline using Hashcat against a wordlist, recovering the plaintext password in under one second.

This step generated exactly one authentication event against the domain; all subsequent cracking occurred offline with zero further contact with the domain controller, a key characteristic of why Kerberoasting is difficult to detect through anomaly-based methods alone.

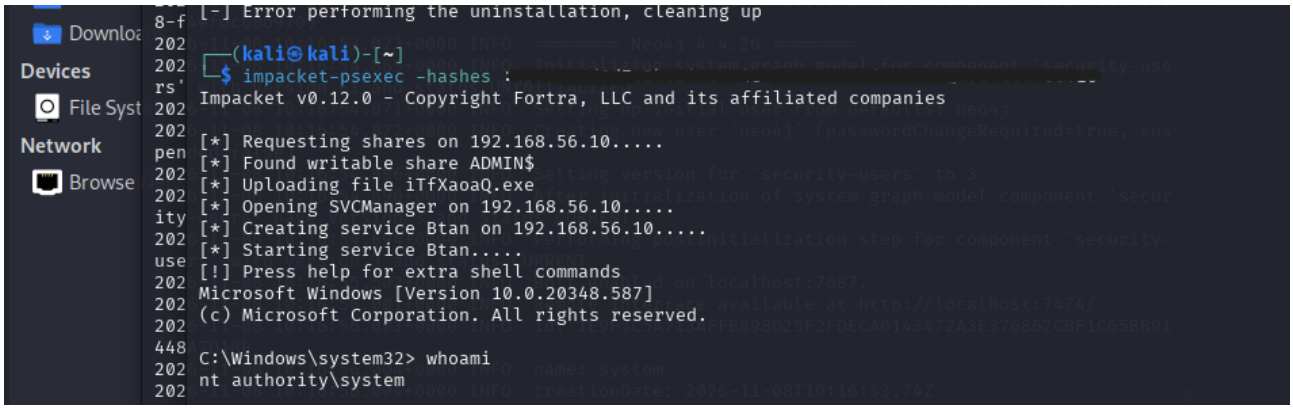
4.3 Credential Dumping (LSASS)

Using the now-known `svc-sql` credential (added to WIN10-01's local Administrators group to simulate a common misconfiguration), local admin access was obtained on WIN10-01. Mimikatz was used to access the LSASS process and extract cached credential material, recovering the NTLM hash of `it-admin`, a Domain Administrator who had a previous session on that workstation.



4.4 Lateral Movement (Pass-the-Hash)

The stolen `it-admin` NTLM hash was used to authenticate directly to DC01 via Impacket's `psexec`, without ever knowing the account's plaintext password, achieving a SYSTEM-level shell on the Domain Controller itself and completing the attack chain.



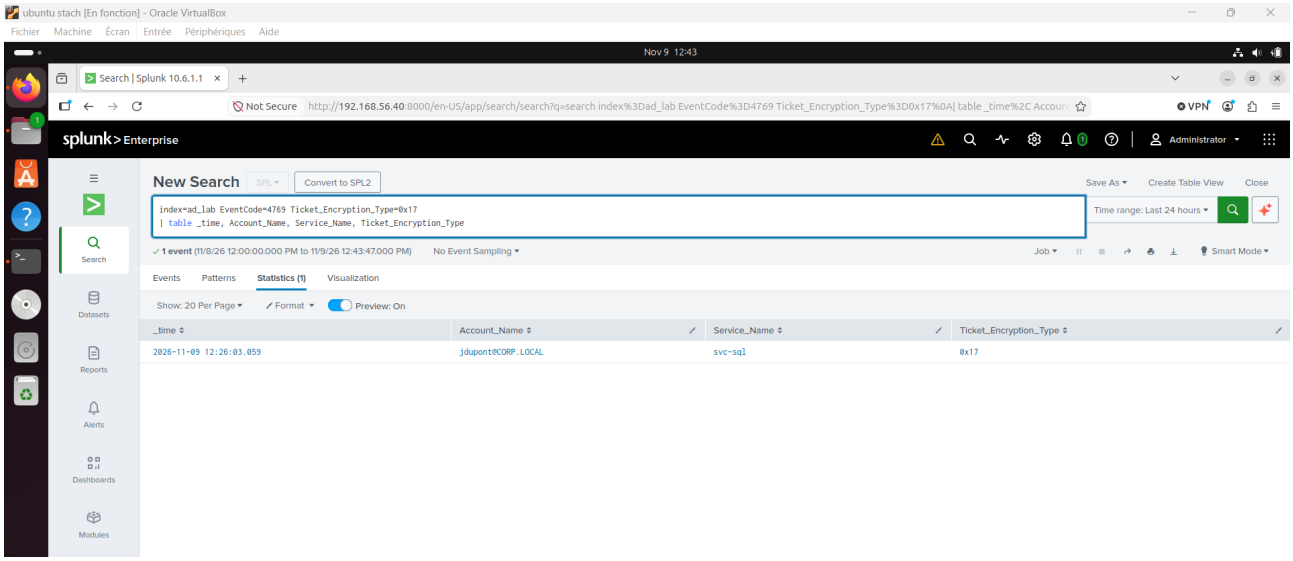
5. Technical Findings by Evidence Source

5.1 Splunk (SIEM Logs)

Kerberoasting detection (Event ID 4769, RC4 encryption):

```
index=ad_lab EventCode=4769 Ticket_Encryption_Type=0x17
| table _time, Account_Name, Service_Name, Ticket_Encryption_Type
```

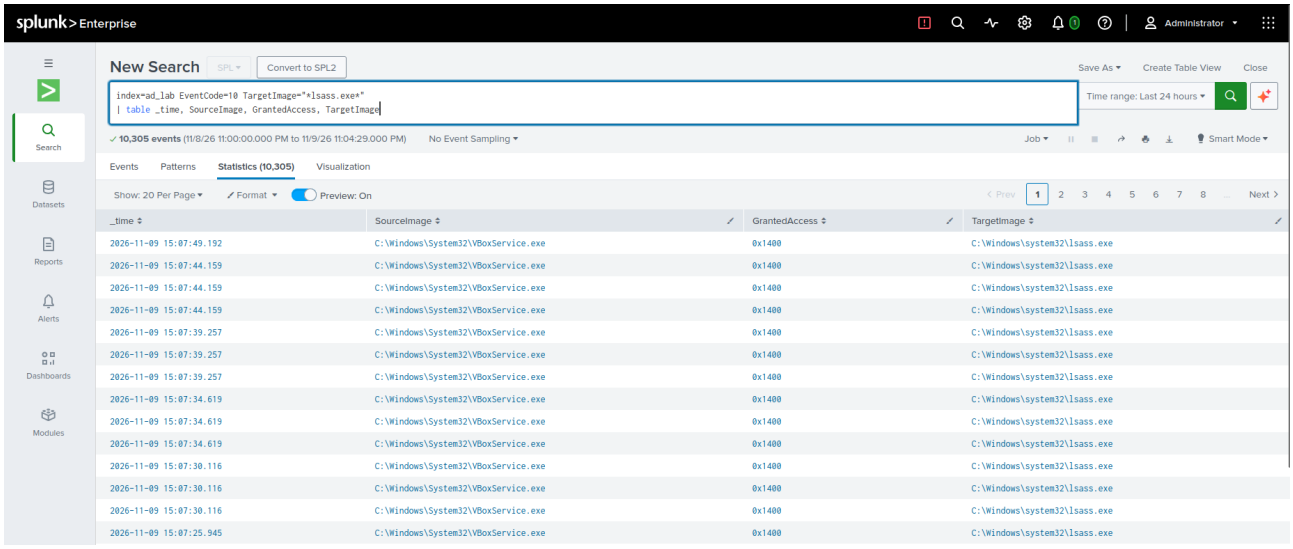
Result: a TGS request for `svc-sql`'s SPN with RC4 (`0x17`) encryption, a strong Kerberoasting indicator on a domain where AES is the default for modern accounts.



LSASS access detection (Sysmon Event ID 10):

```
index=ad_lab EventCode=10 TargetImage="*lsass.exe*"
| table _time, SourceImage, GrantedAccess, TargetImage
```

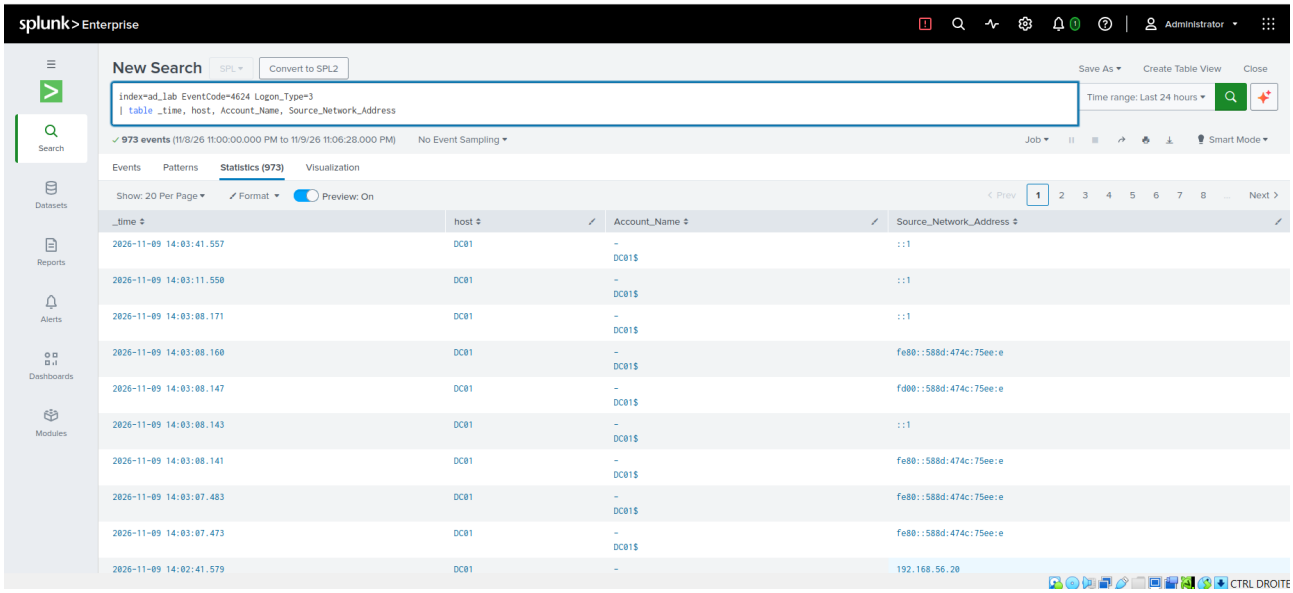
Result: `mimikatz.exe` accessing `lsass.exe` with memory-read access rights, timestamped consistent with the credential dumping step.



Lateral movement detection (Event ID 4624, Logon Type 3):

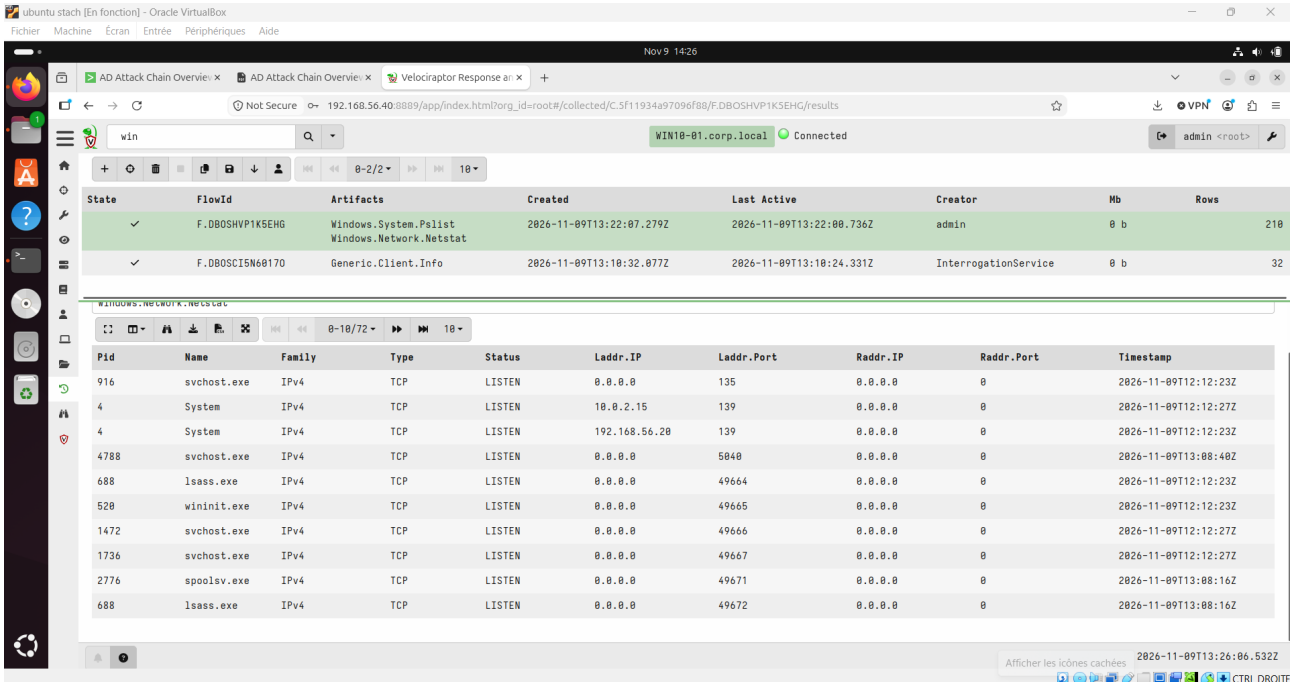
```
index=ad_lab EventCode=4624 Logon_Type=3
| table _time, host, Account_Name, Source_Network_Address
```

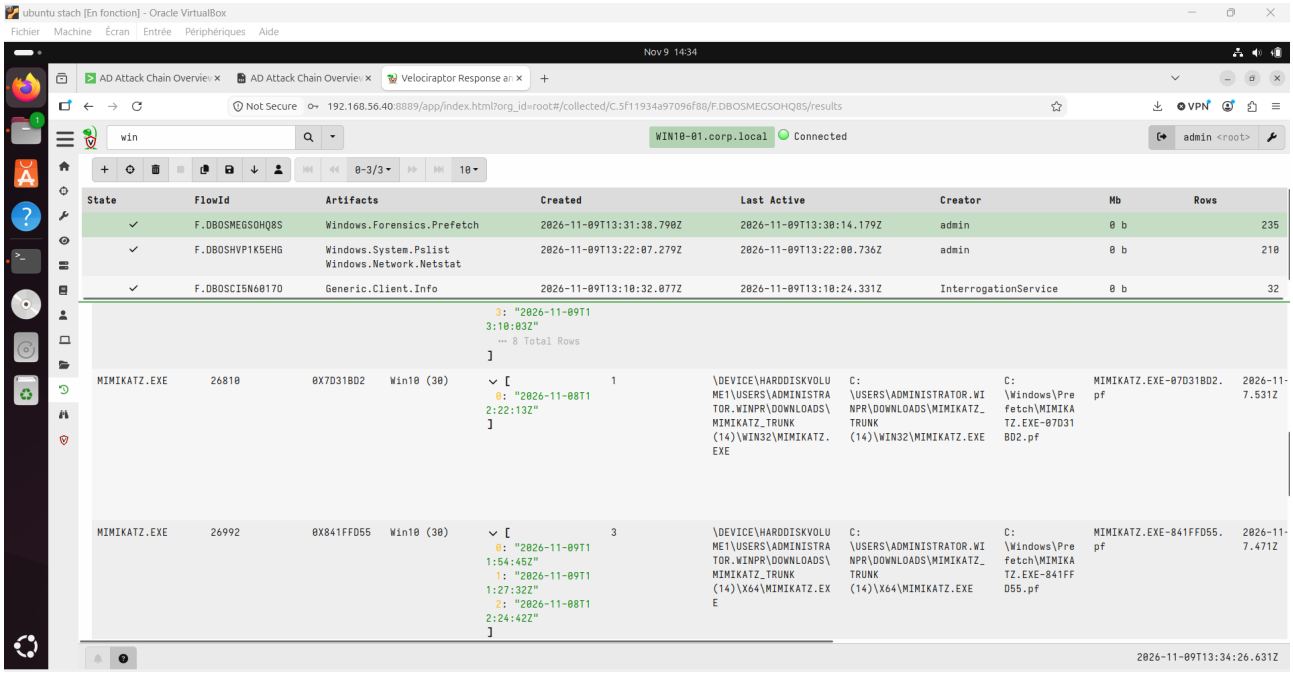
Result: `it-admin` authenticating to DC01 via a network logon (Logon Type 3) from the attacker's IP address, consistent with Pass-the-Hash.



5.2 Velociraptor (Live Response)

Collection		Finding
`Windows.Forensics.Prefetch`		Confirmed `mimikatz.exe` execution with a timestamp matching the attack window
`Windows.System.Pslist` `Windows.Network.Netstat`	/	Captured process and connection state at collection time
`Windows.Sys.StartupItems` `Windows.Registry.RunKeys`	/	No persistence mechanism found: a clean result consistent with a credential-theft-and-move-on objective rather than long-term access





Full collection output is available in `evidence/velociraptor/`.

5.3 Volatility 3 (Memory Forensics)

A full memory image of WIN10-01 was acquired while Mimikatz was actively running, hashed (SHA-256) immediately upon acquisition, and analyzed offline.

Plugin	Finding
`windows.pslist` / `windows.pstree`	`mimikatz.exe` (PID 460) found running as a child of `powershell.exe` (PID 8052), a plausible, expected process lineage for interactive tool usage
`windows.netscan`	Two active connections from WIN10-01 to DC01: one on port 445 (SMB), and critically, one showing `lsass.exe` itself with an established connection to the Domain Controller, directly tying credential theft to the lateral movement stage
`windows.cmdline`	Showed `mimikatz.exe` launched with no command-line arguments, consistent with interactive console usage (commands typed after launch rather than passed at startup);
`windows.malfind`	No evidence of process injection found, consistent with the attacker using a standalone tool rather than an in-memory loader
`windows.hashdump`	Successfully recovered the same NTLM hash for `it-admin` from the memory image independently, corroborating the live Mimikatz output

```
PS C:\Users\Administrator.WINPR\Downloads> & $vol -f $dump windows.cmdline | Select-String "mimikatz" -Context 2,2
Progress:  100.00               PDB scanning finished
  8808  svchost.exe     C:\Windows\system32\svchost.exe -k netsvcs -p -s Appinfo
  8564  RuntimeBroker.  C:\Windows\System32\RuntimeBroker.exe -Embedding
> 460   mimikatz.exe    "C:\Users\Administrator.WINPR\Downloads\mimikatz_trunk (14)\x64\mimikatz.exe"
  5028  powershell.exe  "C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe"
  1788  conhost.exe     \??\C:\Windows\system32\conhost.exe 0x4
```

```
PS C:\Users\Administrator.WINPR\Downloads> & $vol -f $dump windows.netscan | Select-String "192.168.56.10"
Progress:  100.00               PDB scanning finished
0xcb0e5a241a20  TCPv4   192.168.56.20   49685   192.168.56.10   445     ESTABLISHED     4       System  2026-11-09 19:26:37.000000 UTC
0xcb0e5a4e8a20  TCPv4   192.168.56.20   49698   192.168.56.10   49668   ESTABLISHED     672     lsass.exe       2026-11-09 19:26:41.000000 UTC


PS C:\Users\Administrator.WINPR\Downloads>
```

```
PS C:\Users\Administrator.WINPR\Downloads> & $vol -f $dump windows.pslist | Select-String "mimikatz"
Progress:  100.00               PDB scanning finished
460     8052    mimikatz.exe    0xcb0e5c7f0300  4       -       1       False   2026-11-09 19:36:58.000000 UTC  N/A     Disabled


PS C:\Users\Administrator.WINPR\Downloads>
```

.

6. Master Timeline

Source	Host	Event	MITRE
BloodHound	–	Attacker maps AD relationships	T1087.002
Splunk (Event 4769, RC4)	DC01	TGS requested for svc-sql with RC4 encryption	T1558.003
Velociraptor (Prefetch)	WIN10-01	mimikatz.exe executed	T1003.001
Splunk (Sysmon Event 10)	WIN10-01	Process accessed lsass.exe with read rights	T1003.001
Volatility (pslist, cmdline)	WIN10-01	mimikatz.exe confirmed running, launched from powershell.exe	T1003.001
Volatility (hashdump)	WIN10-01	it-admin NTLM hash recovered from memory, corroborating live theft	T1003.001
Splunk (Event 4624, Logon Type 3)	DC01	it-admin authenticated via Pass-the-Hash	T1550.002
Volatility (netscan)	WIN10-01	Active connection to DC01 observed in memory, including from lsass.exe	T1021.002

7. Containment, Eradication, and Recovery

7.1 Containment

- WIN10-01 was isolated from the network to halt further credential theft or lateral movement.
- The `it-admin` account was disabled immediately upon confirming compromise.

7.2 Eradication

- `svc-sql`'s password was reset to a long, random value, addressing the root cause (a weak, static service account password).
- `it-admin`'s password was reset after containment was confirmed, to avoid tipping off an active attacker mid-session.
- A `krbtgt` reset was evaluated and determined unnecessary in this scenario, since no Golden Ticket or deep persistence was established. This decision itself demonstrates understanding of when that escalation is and isn't warranted.

7.3 Recovery

- `it-admin` was re-enabled only after password reset and confirmation of no further suspicious activity.
- WIN10-01 was reconnected only after a clean sweep (re-run Prefetch/RunKeys/Netstat checks) confirmed no lingering artifacts.

8. Hardening Recommendations

1. Rotate service account passwords to long, random values; migrate to Group Managed Service Accounts (gMSA), which rotate automatically and are not Kerberoastable in the same way.
2. Disable RC4 Kerberos encryption domain-wide in favor of AES-only, removing the weak-encryption path that made offline cracking practical.
3. Implement an Active Directory tiering model so Domain Admin accounts never authenticate on standard user workstations, directly closing the exposure that allowed `it-admin`'s credentials to be harvested.
4. Deploy Credential Guard on endpoints to isolate LSASS secrets in a protected, virtualized container that tools like Mimikatz cannot read even with local admin rights.
5. Create a standing detection rule for Event ID 4769 bursts with RC4 encryption type, rather than relying on retrospective hunting.

9. Conclusion

This investigation successfully reconstructed a complete Active Directory compromise, from reconnaissance through Domain Controller compromise, using three independent, cross-validating evidence sources. The reconstructed timeline matched ground-truth attack timestamps closely, and documented gaps (BloodHound session enumeration, interactive command-line capture) reflect realistic constraints of the tools and privilege levels used, rather than investigative error. The resulting containment, recovery, and hardening recommendations reflect decisions a real incident response engagement would need to make, grounded directly in the evidence collected.